

DSG Software Security and Penetration Testing

SSO Configuration Check Report

Application	Nexus DSO Alteryx	PPA #	840600
Pen Test Type	Pre-Production	RP #	851116
Assessment Date	03/21/2024	PTI#	859582
Report Type	Preliminary	Report Date	03/26/2024

THIS REPORT IS DELIVERED TO THE CLIENT TO ASSIST WITH VULNERABILITY REMEDIATION ACTIVITIES. THIS REPORT DOES NOT CARRY AN ENDORSEMENT FROM THE SOFTWARE SECURITY AND PEN TEST TEAM

This report is for KPMG internal use only and its content cannot be shared or distributed in any form with a third party client or vendor without initiating the client inquiry process or obtaining appropriate vendor report.

Assessment Timelines

Assessment Start Date	21 st March, 2024
Assessment Completion Date	26 th March, 2024
Report Updated	

Report History

Name	Company	Email	Description
Krishna Choksi	Blueinfy	krishnachoksi@kpmg.com	Creator
Rishita Sarabhai	Blueinfy	rsarabhai@kpmg.com	Reviewer

Table of Contents

1. Executive Summary	4
2. Overview.....	7
3. Vulnerability Details	8
3.1. Identified Vulnerabilities during PTI 859582.....	8
3.2. Informational/Notes Items	31
4. Appendix.....	44
4.1. Appendix A - Application Risk Score Matrix	44
4.2. Appendix B - 5 STAR Assessment Rating System.....	46
4.3. Appendix C - Terminology	47
4.4. Appendix D - Methodology for Application Assessment	48
4.5. DSG Disclaimer Notice.....	49

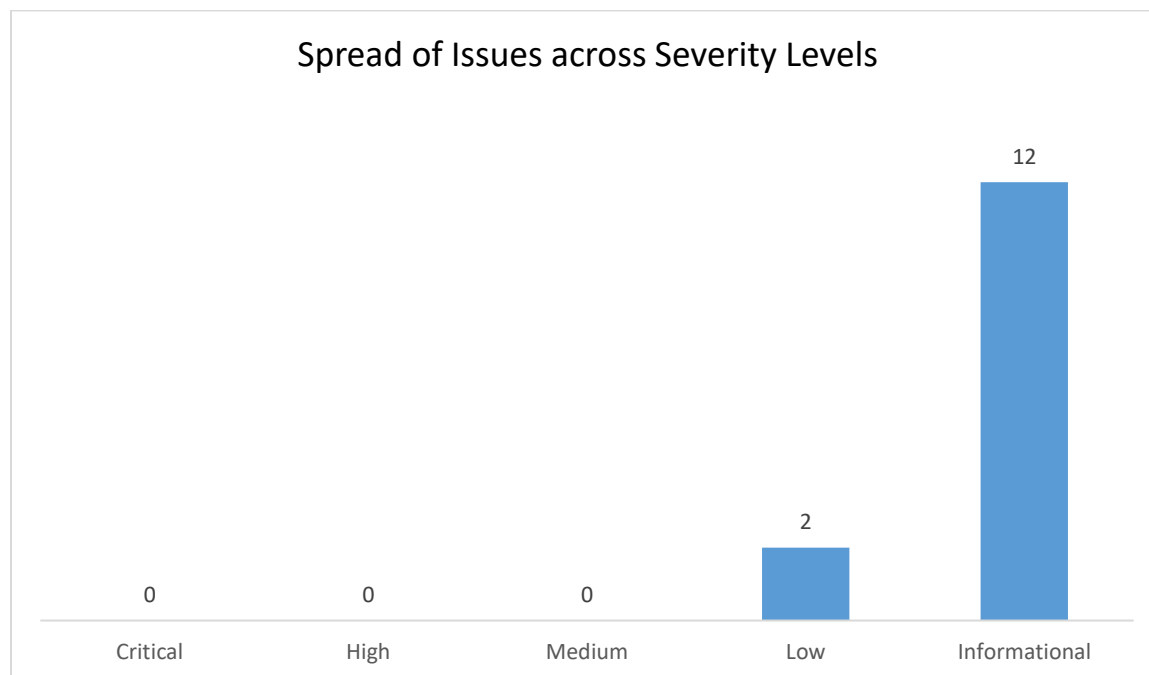
1. Executive Summary

As part of Digital Security Group's (DSG) Software Security and Penetration Testing Program, Blueinfy has conducted vulnerability assessment and configuration check on the SSO implementation for the Nexus DSO Alteryx application.

The Blueinfy team performed time bound security testing through manual methods. Blueinfy has leveraged Burp Suite for conducting the manual test along with other open source security testing software's.

The purpose of this SSO configuration check on the application was to identify the potential vulnerabilities. The manual assessment encompassed the modules of Information gathering, Configuration management, Authentication testing, Authorization testing, session management, Input validation, and encryption to identify the security issues which could potentially affect the application.

Blueinfy Security team has identified a total of 14 vulnerabilities (which includes manual assessment) with multiple instances categorized under varied severity levels. No automated scans were performed for this SSO configuration check. The graph provides a snapshot of the number of issues across Severity Levels.



Vulnerabilities and findings are divided based on their impact (potential damage) and likelihood (probability of identification and exploit). High impact / high likelihood vulnerabilities represent the highest priority and present the greatest threat. Low impact / low likelihood vulnerabilities are the lowest priority and present the smallest threat. See Appendix C for more information.

The list of identified vulnerabilities that are open as of 03/26/2024 has been provided below:

#	Vulnerability	Risk Rating	Dependency	Updated Risk Rating	From Previous Pen Test?
1.	Logout Functionality Malfunction	Low	Application		
2.	Application does not Redirect upon Session Expiration	Low	Application		
3.	Weak Content Security Policy (Improper CSP header leads to XSS)	Low	Okta	Informational	
4.	Misconfigured/Insecure Response Header	Low	Okta	Informational	
5.	Potential SLOWLORIS DOS Attack	Low	Okta	Informational	
6.	Sensitive Information displayed in URL	Low	Okta	Informational	
7.	SAML - Weak Canonicalization Method Used	Low	Okta	Informational	
8.	Session Fixation	Low	Okta	Informational	
9.	KPMG Network Credentials sent to Vendor Hosted System (Over the Internet)	Low	Okta	Informational	
10.	Missing Referrer-policy Header	Informational	Okta		
11.	Webserver Version Revealed	Informational	Okta		
12.	Concurrent User Session	Informational	Okta		
13.	CBC-mode Encryption in TLS (Lucky 13 attack)	Informational	Okta		
14.	Webserver Metafiles for Information Leakage	Informational	Okta		

The additional details pertaining to the vulnerability assessment & SSO configuration check of the application is provided below.

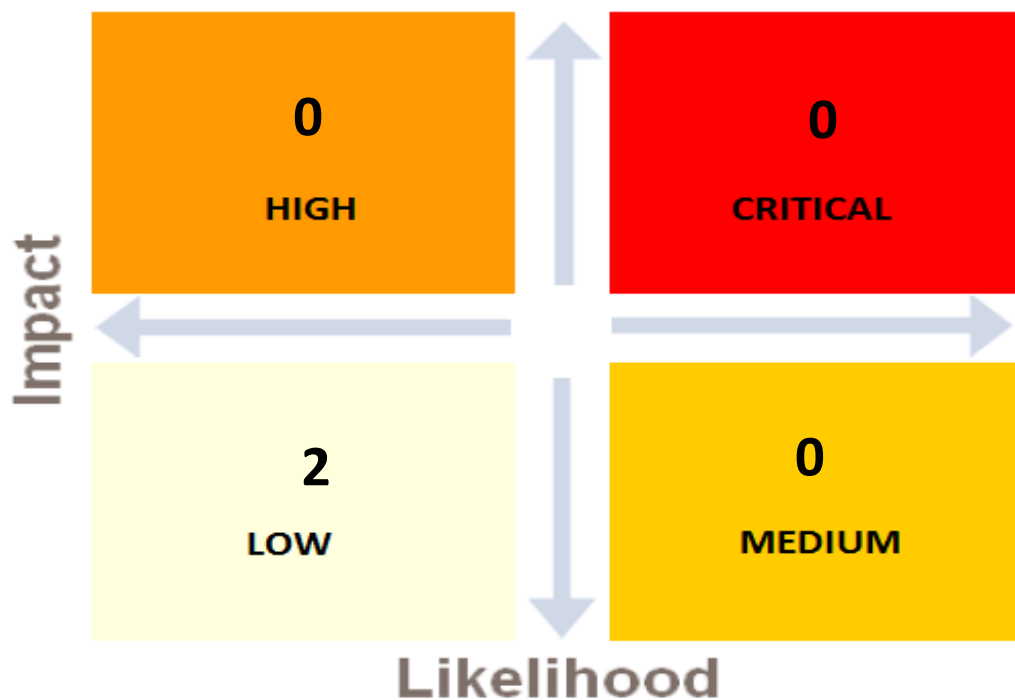
Test URL	https://dsoalteryxuat.us.kworld.kpmg.com/gallery https://kpmgstaging.oktapreview.com https://kpmgstaging.kerberos.oktapreview.com
Testing Environment	Non-Production
Number of Access Level in Scope	6
User Roles	1. Artisan 2. Curator 3. Default 4. Member 5. NoAccess 6. Viewer
Scope of Test	Limited
Testing Window	N/A
Point of Contact (App Team)	Mir, Imran Pervez

Disclaimer: *This report contains examples of instances where certain vulnerabilities have been identified. However, the issue may not be only limited to the instances reported. We certainly advise that a global fix be implemented to remediate all vulnerabilities and not limit the remediation to just the instances identified in this report.*

2. Overview

The table below provides an overview of the SSO configuration check conducted on the Nexus DSO Alteryx application.

Project/Application	Nexus DSO Alteryx
Type of Testing	Pre-Production SSO Configuration Check
Assessment Date	21st March, 2024
Type of Assessment	Dynamic Manual Assessment
Tools Used	Burp Suite & other Open Source Tools
Total Number of Issues	14 (2 Low and 12 Informational)
STAR Rating	4 Star ★★★★★



Additionally, 12 Informational issues has been reported as part of the testing activity.

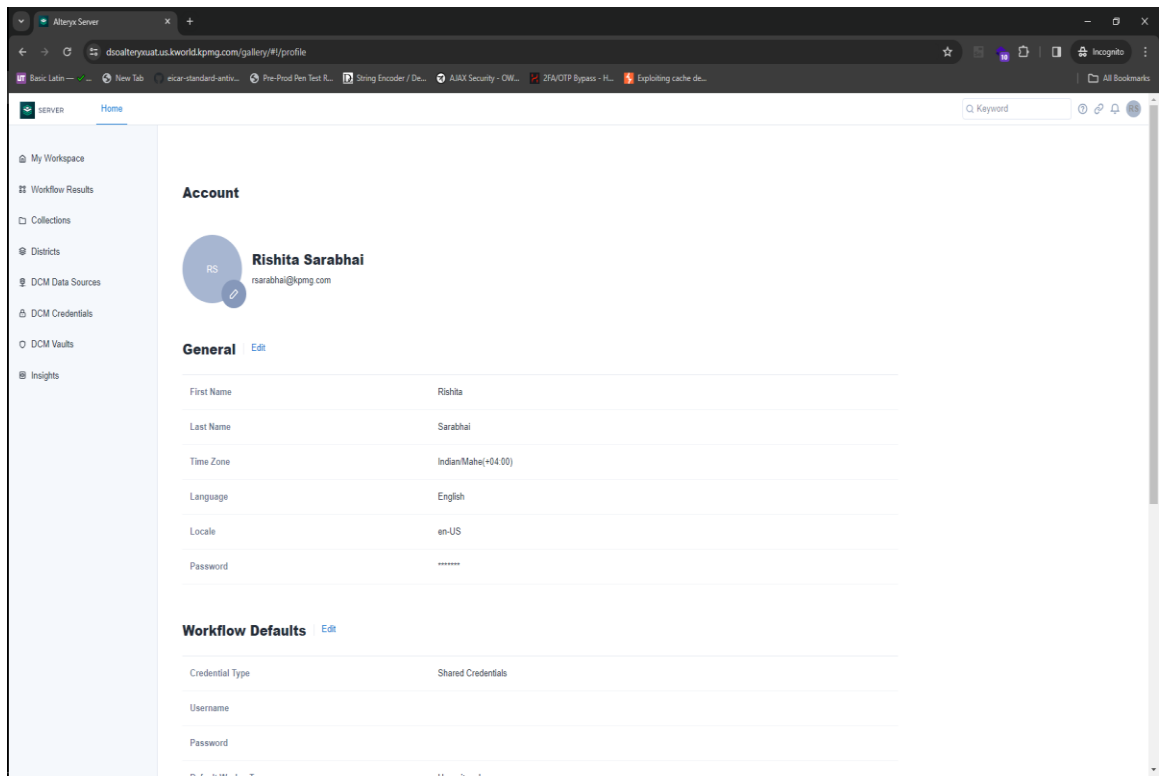
3. Vulnerability Details

3.1. Identified Vulnerabilities during PTI 859582

This section contains vulnerabilities that are identified during the **pre-production (limited scope)** test. This SSO configuration check was conducted during **03/21/2024 and 03/26/2024**.

Vulnerability	1. Logout Functionality Malfunction		Status	Open					
Risk Rating	Low	Vulnerability Owner	Application						
Issue Description:	The application has a logout button but it is not working as expected. The application throws an error (500 Error) due to which it does not invalidate the session and the user can not logout to the application. Additionally, a call is not made to the KPMG IdP to invalidate the IdP session and the user can re-login without entering credentials till the browser is not closed.								
URL	https://dsoalteryxuat.us.kworld.kpmg.com/gallery/api/auth/sessions/								
Screenshots: # Host Meth... URL Para... Edited Status ... Lang... MIME... Exten... Time TLS IP Cookies Listene... Title 2025 https://dsoalteryxuat.us.kworld.kpmg.com DELETE /gallery/api/auth/sessions/ 500 98 XML 15:58:3... ✓ 10:36:202... 8080 Request Response Pretty Raw Hex 1 DELETE /gallery/api/auth/sessions/ HTTP/1.0 2 Host: dsoalteryxuat.us.kworld.kpmg.com 3 Cookie: PD_STATEFUL_94718fcc-e57a-11eb-bbb8-005056ab0dd7=dsoalteryxuat-us-kworld-kpmg-com-https; amp_API_KEY=9c8t43m4q3ueOh50TVFPo...lhpq0blb6.lhpq0gh5d.0.0.0 4 Sec-Ch-Ua: "Not(A:Brand";v="24", "Chromium";v="122" 5 X-Authorization: SPECIAL 6 Sec-Ch-Ua-Mobile: ?0 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.6261.112 Safari/537.36 8 Sec-Ch-Ua-Platform: "Windows" 9 Accept: /*/* 10 Origin: https://dsoalteryxuat.us.kworld.kpmg.com 11 Sec-Fetch-Site: same-origin 12 Sec-Fetch-Mode: cors 13 Sec-Fetch-Dest: empty 14 Referer: https://dsoalteryxuat.us.kworld.kpmg.com/gallery/ 15 Accept-Encoding: gzip, deflate, br 16 Accept-Language: en-US,en;q=0.9 17 Priority: u=1, i 18 Connection: keep-alive 19 20 1 HTTP/1.0 500 Error 2 X-Backside-Transport: FAIL FAIL 3 Content-Type: text/xml 4 Connection: close 5 6 <tr><th colspan="1">Remediation</th><td colspan="4">The logout functionality should be working properly to invalidate the session and redirect user to login page. The logout functionality should be configured</td></tr>					Remediation	The logout functionality should be working properly to invalidate the session and redirect user to login page. The logout functionality should be configured			
Remediation	The logout functionality should be working properly to invalidate the session and redirect user to login page. The logout functionality should be configured								

	to make a call to the KPMG IdP along with invalidating the application session cookies.
(Closing/Down grading) Justification	

Vulnerability	2. Application does not Redirect upon Session Expiration		Status	Open
Risk Rating	Low	Vulnerability Owner	Application	
Issue Description:	After the user's session ends from a period of inactivity, the page does not redirect to the logout screen or the login page. Anyone who has access to the computer can view the contents of the page contents of the page which will be a risk if it has sensitive information.			
URL	https://dsoalteryxuat.us.kworld.kpmg.com/			
Screenshots: 				
Remediation	Redirect user to logout screen after session times out.			
(Closing/Down grading) Justification				

Vulnerability	3. Weak Content Security Policy (Improper CSP header leads to XSS)		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The Content Security Policy header allows you to define a whitelist of approved sources of content for your site. By restricting the assets that a browser can load for your site, like js and css, CSP can act as an effective countermeasure to XSS attacks. The configured CSP uses unsafe attributes like unsafe-inline and unsafe-eval and certain directives.			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED <u>Instance 2:</u> https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDsso/interact?precheck=false&interactionHandle=cINjNVhGV3NUcENVWDZ3bEF5QkNqdzdmd3dSYlJpcHFOR2RGTW5pWWwrZWWhSZjRVOXZlZTR3cmxFa1FRRURO Mg			
<u>Instance 1: (Informational)</u> <u>Screenshots:</u>				

Content Security Policy

Sample unsafe policy Sample safe policy

```
default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com
kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com *.mtls.oktapreview.com
kpmgstaging-kerberos.oktapreview.com *.authenticator.localprod.com:8769 http://localhost:8769 http://127.0.0.1:8769
http://localhost:65121 http://127.0.0.1:65121 *.authenticator.localprod.com:65131 http://localhost:65131
http://127.0.0.1:65131 *.authenticator.localprod.com:65141 http://localhost:65141 http://127.0.0.1:65141
http://localhost:65141 *.authenticator.localprod.com:65151 http://localhost:65151 http://127.0.0.1:65151
data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-539152187216064.storage.googleapis.com;
script-src 'unsafe-inline' 'unsafe-eval' 'self' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline'
kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com *.mtls.oktapreview.com data:
kpmgstaging-admin.oktapreview.com login.okta.com *.okta-authenticator.com; img-src 'self' kpmgstaging.oktapreview.com
*.oktacdn.com *.tiles.mapbox.com *.mapbox.com data: data.pendo.io pendo-static-5634101834153984.storage.googleapis.com
http://localhost:8769 http://localhost:8769 http://localhost:8769 http://localhost:8769 http://localhost:8769 http://localhost:8769
*.oktacdn.com fonts.gstatic.com; frame-ancestors 'self';
```

CSP Version 3 (nonce based + backward compatibility checks) 

CHECK CSP

Evaluated CSP as seen by a browser supporting CSP Version 3

expand/collapse all

✓ <code>default-src</code>	
✓ <code>connect-src</code>	
✗ <code>script-src</code>	Host whitelists can frequently be bypassed. Consider using 'strict-dynamic' in combination with CSP nonces or hashes.
✗ <code>'unsafe-inline'</code>	'unsafe-inline' allows the execution of unsafe in-page scripts and event handlers.
✗ <code>'unsafe-eval'</code>	'unsafe-eval' allows the execution of code injected into DOM APIs such as eval().
✗ <code>'self'</code>	'self' can be problematic if you host JSONP, Angular or user uploaded files.
✗ <code>kpmgstaging.oktapreview.com</code>	No bypass found; make sure that this URL doesn't serve JSONP replies or Angular libraries.
✗ <code>*.oktacdn.com</code>	No bypass found; make sure that this URL doesn't serve JSONP replies or Angular libraries.
✓ <code>style-src</code>	
✓ <code>frame-src</code>	
✓ <code>img-src</code>	
✓ <code>font-src</code>	
✓ <code>frame-ancestors</code>	
✗ <code>object-src [missing]</code>	Can you restrict object-src to 'none'?
✗ <code>require-trusted-types-for [missing]</code>	Consider requiring Trusted Types for scripts to lock down DOM XSS injection sinks. You can do this by adding "require-trusted-types-for 'script'" to your policy.

Legend

- ① High severity finding
- ② Medium severity finding
- ③ Possible high severity finding
- Directive/value is ignored in this version of CSP
- ④ Possible medium severity finding
- ✖ Syntax error

Screenshots:

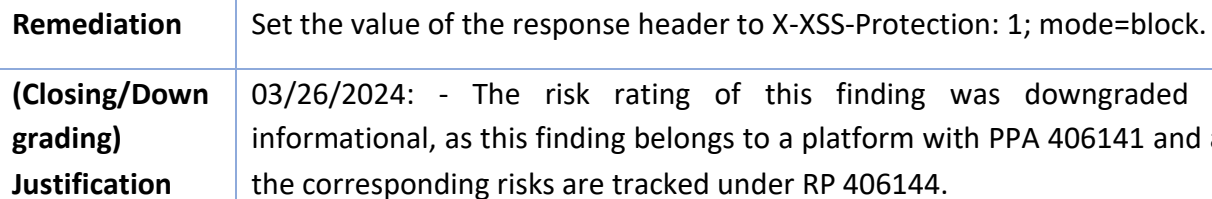
	restrictions, it drastically reduces your attack surface and will work with most modern browsers. For configuring the CSP, please refer to the below links: - https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP https://csp-evaluator.withgoogle.com/
(Closing/Down grading) Justification	03/26/2024: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141 and all the corresponding risks are tracked under RP 406144.

Instance 1: (Informational)

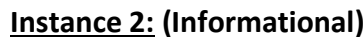
Screenshots:

15 | Page

Screenshots:



Vulnerability	5. Potential SLOWLORIS DOS Attack		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	Slowloris is a denial-of-service attack program which allows an attacker to overwhelm a targeted server by opening and maintaining many simultaneous HTTP connections between the attacker and the target. It is an application layer attack which operates by utilizing partial HTTP requests. The attack functions by opening connections to a targeted Web server and then keeping those connections open as long as it can. It is a specific attack tool designed to allow a single machine to take down a server without using a lot of bandwidth. Unlike bandwidth-consuming reflection-based DDoS attacks such as NTP amplification, this type of attack uses a low amount of bandwidth, and instead aims to use up server resources with requests that seem slower than normal but otherwise mimic regular traffic. It falls in the category of attacks known as “low and slow” attacks. The targeted server will only have so many threads available to handle concurrent connections. Each server thread will attempt to stay alive while waiting for the slow request to complete, which never occurs. When the server’s maximum possible connections has been exceeded, each additional connection will not be answered and denial-of-service will occur. Tool Used: NMap			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com <u>Instance 2:</u> https://kpmgstaging.kerberos.oktapreview.com			
<u>Instance 1: (Informational)</u>				
<u>Screenshots:</u>				

[illegible]

Remediation	For web servers that are vulnerable to Slowloris, there are ways to mitigate some of the impact. Mitigation options for vulnerable servers can be broken down into different categories: - 1. Increase the maximum number of clients the web server will allow 2. Limit the number of connections a single IP address is allowed to attempt 3. Place restrictions on the minimum transfer speed a connection is allowed 4. Constrain the amount of time a client is permitted to stay connected In the case of Apache web servers, several modules can be employed to prevent damage from a Slowloris attack. These modules include: • Mod_limitipconn • Mod_qos • Mod_evasive • Mod_security • Mod_noloriss • Mod_antiloris Apache 2.2.15 includes the module mod_reqtimeout, which is the solution supported by the developers. Additional approaches for Slowloris DDoS protection include instituting reverse proxies, firewalls, load balancers or content switches.
(Closing/Down grading) Justification	03/26/2024: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141 and all the corresponding risks are tracked under RP 406144.

Vulnerability		6. Sensitive Information displayed in URL		Status	Open	
Risk Rating		Informational		Vulnerability Owner		Okta
Issue Description:		The application sends sensitive information as a variable within the URL as a query string parameter. Information sent in the URL query string is logged in several places, such as the client browser, intermediate proxy servers and web server logs and is susceptible to shoulder surfing attacks.				
URL		https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.b5RtBFaNwjpXLLn7b66RvNBkQBCOF7Pq7VIEEmE				
Screenshots: 86https://kpmgstaging.oktapreview.comGET/login/token/redirect?stateToken=02.id.b5RtBFaNwjpXLLn7b66RvNBkQBCOF7Pq7VIEEmE20041907HTMLKPMGStaging - Signing in...99.83.191.34sid=""autolaunch...14:42:19 21...8080 RequestResponse PrettyRawHex 1GET /login/token/redirect?stateToken=02.id.b5RtBFaNwjpXLLn7b66RvNBkQBCOF7Pq7VIEEmE HTTP/2 2Host: kpmgstaging.oktapreview.com 3Cookie: t=defauit: DT=0114F0hnP0hQ2mPly0r4LvTow: lmrswarabhai@kpmg.com; JSESSIONID=3CE20C543318680D55630835E2FC67D9 4Sec-Ch-Ua: "Not A Brand";v="8", "Chromium";v="120" 5Sec-Ch-Ua-Mobile: ?0 6Sec-Ch-Ua-Platform: "Windows" 7Sec-Ch-Ua-Platform-Version: "" 8Upgrade-Insecure-Requests: 1 9User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36 10Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 11Sec-Fetch-Site: same-origin 12Sec-Fetch-Mode: navigate 13Sec-Fetch-User: ?1 14Sec-Fetch-Dest: document 15Referer: https://kpmgstaging.oktapreview.com/login/agentlessDemo/sdx?stateToken=51Q2PdH1VjYjU0M4U1I3RnEvdXkxMTI0OGVYXzFhVWZlbnVWZlR0bGhTdGVVWlZlZGhnaXAla0ltbWVpZG9recheckFailure=true&redirectFromIdso=true 16Accept-Encoding: gzip, deflate, br 17Accept-Language: en-US,en;q=0.9 18Priority: u=0, i 19 20						
Remediation		Send all sensitive information as parameters via POST request.				
(Closing/Down grading) Justification		03/26/2024: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141 and all the corresponding risks are tracked under RP 406144.				

Vulnerability	7. SAML - Weak Canonicalization Method Used	Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta
Issue Description:	In order, that logically-identical XML documents give identical digital signatures, an XML canonicalization transform is employed when signing XML documents. These algorithms guarantee that semantically-identical documents produce exactly identical serialized representations. In this scenario, it is observed that the xml-exc-c14n# method is used, which is known to have possible XML injection vulnerabilities while the comments within the XML Details on SAML XML Injection can be found here: https://research.nccgroup.com/2021/03/29/saml-xml-injection/		
URL	https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.b5RtBFaNwjpXLln7b66RvNBkQBcoF7Pq7VIEEmE		
Screenshots:			
Remediation	Use the xml-exc-c14n#WithComments algorithm instead.		

(Closing/Down grading) Justification	03/26/2024: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141 and all the corresponding risks are tracked under RP 406144.
---	---

Vulnerability	8. Session Fixation		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	In a session fixation attack, the user is tricked into using a session identifier chosen by the attacker before the user even logs into the web application on the target server. i.e. the user’s session identifier has been fixed in advance by the attacker instead of being generated randomly at login. HTTP is a stateless protocol, which means that it does not maintain state throughout a user’s subsequent requests. Web servers/web applications implement session management to maintain session data and achieve statefulness. The server generates a session identifier and sends this identifier to the client (user’s browser). The client identifies itself by sending this unique identifier with each subsequent request. To perform a session fixation attack the attacker uses any one of the transport mechanisms – URL arguments, hidden form fields and cookies to maintain sessions in a web environment.			
URL	https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.dPS8myVlspOf_Z0RyK_i2cCdNv1rv1eJrSNq5skJ			
<u>Reproduction Steps:</u>				
1. Open the URL "https://kpmgstaging.oktapreview.com/" 2. Observe the response 3. The application sets "stateToken" in the response before login 4. Log in to the application 5. Intercept the request using a proxy tool 6. Copy the target URL (URL with "stateToken") 7. Drop the request 8. Open the copied URL in an unauthenticated browser 9. This will allow to log in to the application using "stateToken" which is set before login				
<u>Screenshots:</u>				

The screenshot displays the Burp Suite interface. The top section shows a request to `https://kpmgstaging.oktapreview.com` with a status of 200. The request body is a JSON object containing various fields, including `stateToken` and `stateToken`. The bottom section shows a context menu with the following options:

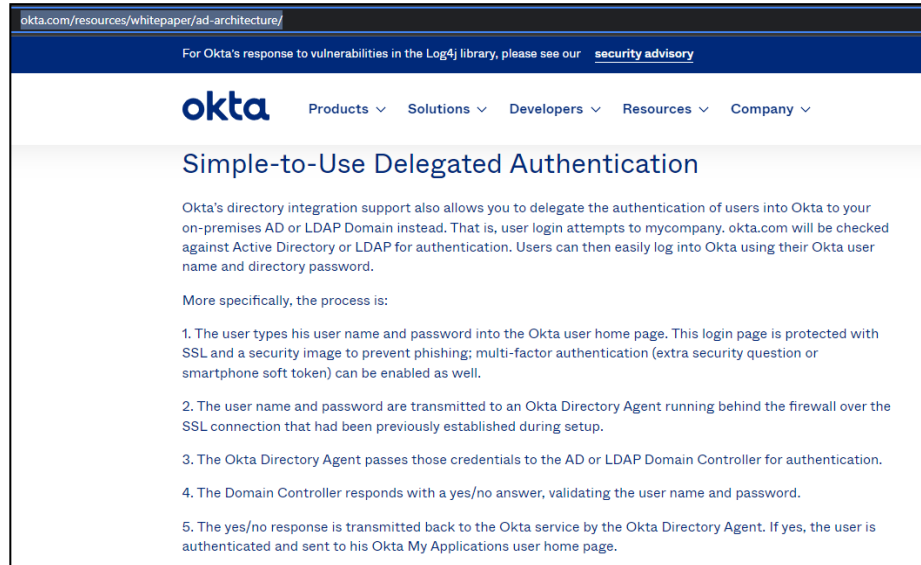
- Scan
- Do passive scan
- Do active scan
- Send to Intruder
- Send to Repeater
- Send to Sequencer
- Send to Comparer
- Send to Decoder
- Send to Organizer
- Insert Collaborator payload
- Request in browser
- Extensions
- Engagement tools
- Change request method
- Change body encoding
- Copy URL**
- Copy as curl command (bash)
- Copy to file
- Paste from file
- Save item
- Don't intercept requests
- Do intercept
- Convert selection
- URL-encode as you type
- Cut
- Copy
- Paste
- Message editor documentation
- Proxy interception documentation

The screenshot displays a web browser window with two tabs. The top tab is titled 'New Incognito tab' and shows a login page for 'kpmgstaging.oktapreview.com'. The URL bar contains a long, complex token-based URL. The page features a circular logo with a hat and glasses, and text indicating 'You've gone Incognito'. Below this, there is a message about privacy and a list of items Chrome won't save. The bottom tab is titled 'My Apps Dashboard | KPMGStaging' and shows a dashboard with a search bar and a grid of application tiles. The tiles are organized into a 'Work' section and include various logos and names such as WageWorks, Quick Base, Validis, ICIMS, Lucidchart, Lucidspark, Remesh, Shibumi, DealCloud, Secure Code Warrior, Bright Horizons App, Change Leadership Index, Credly, SuccessFactors, Iron Mountain, Alexa Translation Tool, Leave of Absence mySeagwick, Informatica Data Masking Dev, T.METTRACK, Fastpath Assure, Designtrackdev, Cvent, and TimetrackQA. The dashboard also includes a sidebar with 'My Apps', 'Work', 'Add section', and 'Notifications' sections.

Remediation	Invalidate the old session identifier and issue a new one. Use a nonce token to identify sessions. Generate a secret token when a user logs in to the
-------------	---

	application, keep the token at the server and include this token in every link and sensitive form. Ensure that the token generated is sufficiently random.
(Closing/Down grading) Justification	03/26/2024: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141 and all the corresponding risks are tracked under RP 406144.

Vulnerability	9. KPMG Network Credentials sent to Vendor Hosted System (Over the Internet)		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	There are two authentication mechanisms for this implementation – one of the two (form-based authentication) sends KPMG network credentials over the internet to a third party owned network (Okta). Application pen testing team interviewed Okta technical consultant in presences of Security architect team and KPMG Okta solution engineering team. Okta consultant confirmed that Okta has the technical ability to read KPMG passwords in cleartext in many cases such as and not limited to SSL offloading and memory dumps. However, they provided the following mitigation controls that Okta believes it will mitigate the risk. [EXTERNAL] KPMG: WageWorks Pen Test Results - Password Protections Follow-up  Susie Godfrey <susie.godfrey@okta.com> To : Manda, Lokesh Babu; Schellenberg, Greg; Dugan, Michael; Jacob, Vinu; Polonetsky, Steve; Maher, Patrick; Wassef, Sam Click here to download pictures. To help protect your privacy, Outlook prevented automatic download of some pictures in this message. Reply Reply All Forward Wed 1/12/2022 8:34 AM Hi Team, Good morning! Please find Okta's response below regarding your questions during our meeting yesterday about password security controls. Okta has in place controls to protect the security of passwords submitted into the Service. This currently includes, but is not limited to: - Secure code training to reduce the likelihood of capturing passwords in logs - Monitoring of logs to detect misconfigurations that may capture customer passwords - Limitation of access to systems (such as networking, infrastructure, and applications that would enable an employee to view or intercept customer passwords that traverse the service) to only those individuals with a business need - Monitoring of employee use of privileged commands, such as infrastructure changes, memory dumps, or process access, that would allow an employee to view or intercept customer passwords - A separate Defensive Cyber Operations team as part of Okta's Security team to investigate and respond to alerts Please reach out if there is any additional information I can provide to assist with your review. -- Susie Godfrey Sr. Customer Success Manager 734-233-4087			
The mentioned controls are out-side the scope of application pen-testing. On the other hand, the pen-testing team refers to the published architecture on Okta website https://www.okta.com/resources/whitepaper/ad-architecture/				



As per the above screen shot, Okta confirms that the username and password are transmitted over SSL, but it does not mention the SSL termination point. Okta consultant clarified that there is SSL offloading occurs before the server farm.

In addition, the above written response from Okta didn't mention the SSL connection is established between the browser and the directory agent as mitigation control.

Next, the pen-testing team refers to KPMG's password security standards document. The standard states firmly that KPMG passwords must be kept secret from those who do not own it.

3 Security Standard - Passwords

3.1 Preface

A password is a sequence of characters that is used for authentication, to prove identity or gain access to a resource (example: an access code is a type of password). The password must not be shared and must be kept secret from those who do not own the password. Access to assets (including devices, systems, networks and information) is based on business requirements, information classification and information security risks. Password mechanisms are an established approach to prove identity (authentication) to gain access to a resource.

These requirements support the *KPMG Global Information Security Policies* as per the referenced mappings to ISO controls and associated KPMG policy statements.

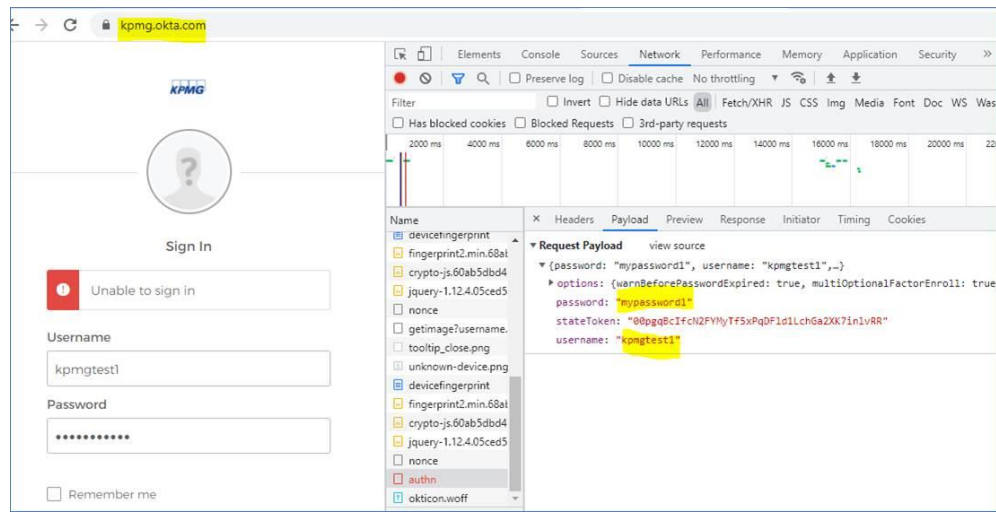
Additional security standards reference

<https://cwe.mitre.org/data/definitions/319.html>

<https://cwe.mitre.org/data/definitions/312.html>

<https://cwe.mitre.org/data/definitions/256.html>

It is extremely important to note the vulnerability exists in production “kpmg.okta.com”

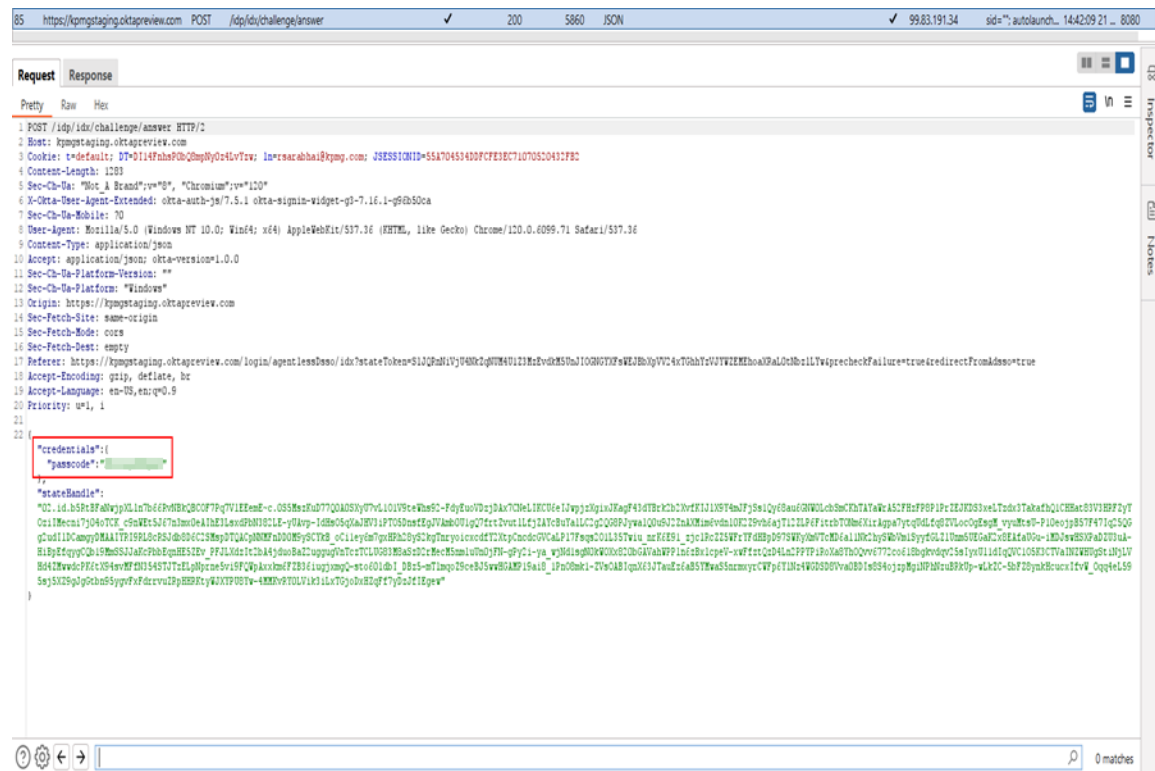


Accordingly, the risk from application security perspective is high.

URL

<https://kpmgstaging.oktapreview.com/idp/idx/challenge/answer>

Screenshots:



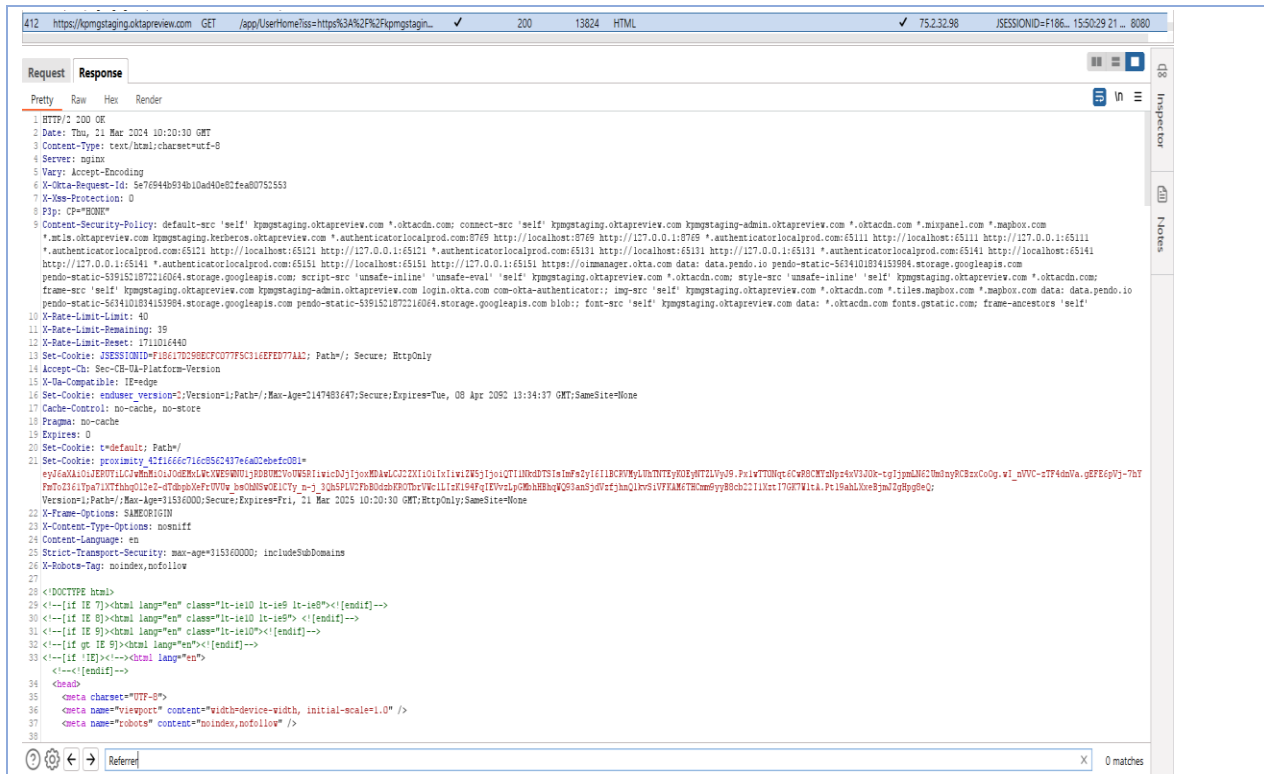
Remediation

KPMG network credentials must be kept secret during rest and in motion till it reach the directory agent.

(Closing/Down grading) Justification	03/26/2024: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141 and all the corresponding risks are tracked under RP 406144.
---	---

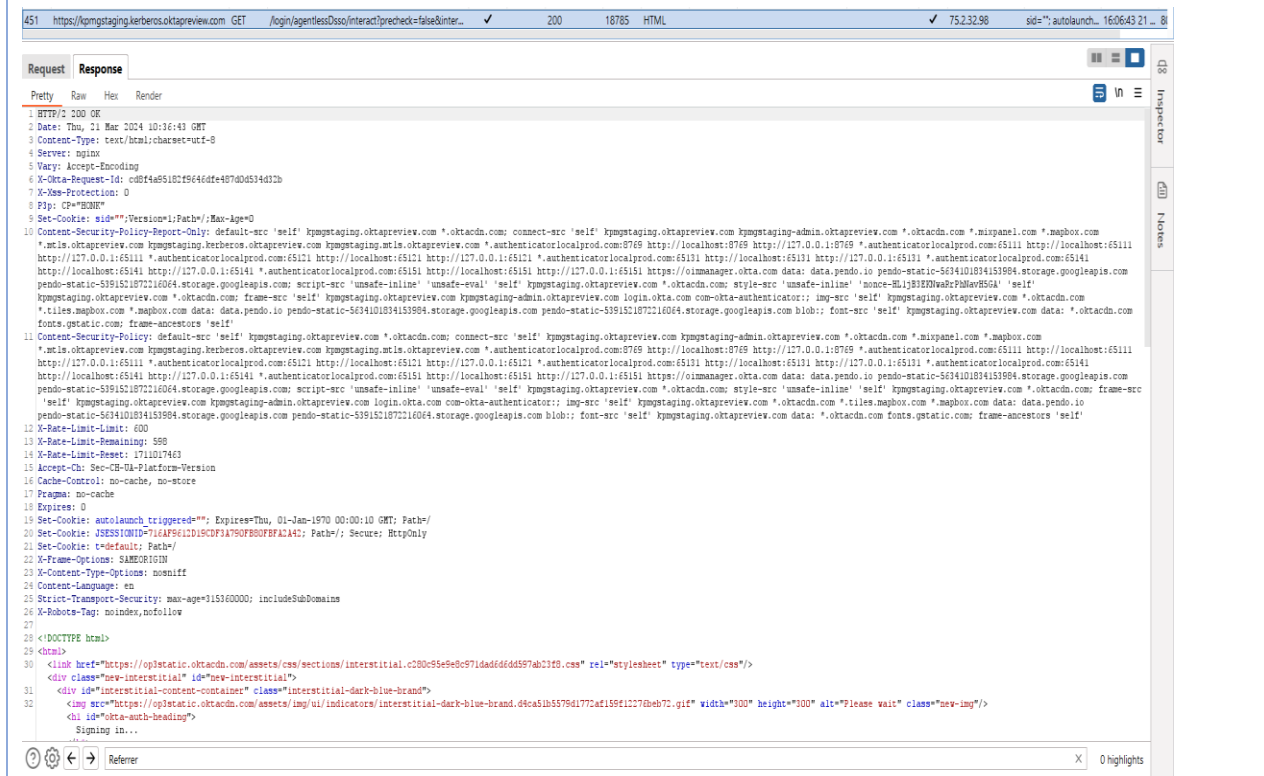
3.2. Informational/Notes Items

Vulnerability	10. Missing Referrer-policy Header		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The Referrer-Policy HTTP header controls how much referrer information (sent via the Referer header) should be included with requests. You can also set referrer policies inside HTML. For example, you can set the referrer policy for the entire document with a <meta> element with a name of referrer. This design will ensure that no sensitive information is leaked through the Referer header.			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED <u>Instance 2:</u> https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDsso/interact?precheck=false&interactionHandle=cINjNVhGV3NUcENVWDZ3bEF5QkNqdzdmd3dSYIJpcHFOR2RGTW5pWWwrZWWhSZjRVOXZIZTR3cmxFa1FRRURO Mg			
<u>Instance 1: (Informational)</u> <u>Screenshots:</u>				



Instance 2: (Informational)

Screenshots:



Remediation	Please refer to the link: - https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy in order to set this header.
(Closing/Down grading) Justification	

Vulnerability	11. Webserver Version Revealed		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The application displays webserver version. This allows an attacker to determine known vulnerabilities and the appropriate exploits to use.			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED <u>Instance 2:</u> https://kpmgstaging.oktapreview.com/enduser/api/v1/sections?type=all&expand=items%2Citems.resource <u>Instance 3:</u> https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDssso/interact?precheck=false&interactionHandle=clNjNVhGV3NUcENVWDZ3bEF5QkNqdzdmd3dSYlJpcHFOR2RGTW5pWWwrZWwSZjRVOXZlZTR3cmxFa1FRRURO Mg <u>Instance 4:</u> https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDssso/interact?precheck=false&interactionHandle=TDdvUHJiT2VnOFptUjJlRGlvaGtZMkl yamUyYW1HOFd6TkhXTHZOZUQwaVI5ZVVNdjhETnhvdkplcE5WWDB0dA			
<u>Instance 1: (Informational)</u> <u>Screenshots:</u>				

Instance 2: (Informational)

Screenshots:

35 | Page

Instance 3: (Informational)

Screenshots:

451 https://kpmgstaging.kerberos.oktapreview.com GET /login/agentlessDso/interact?precheck=false&inter... 200 18785 HTML 752.3298 sid="autolaunch... 160643 21 ... 8

Request **Response**

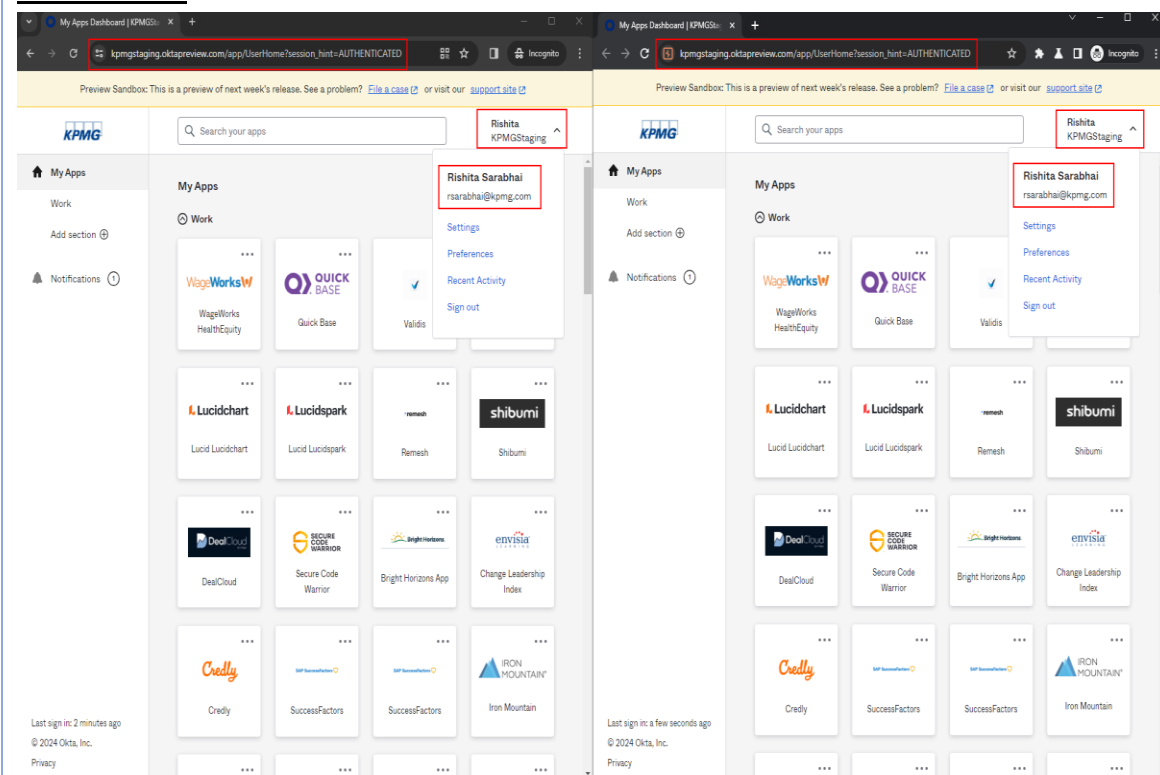
Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Thu, 21 Mar 2024 10:16:43 GMT
3 Content-Type: text/html; charset=utf-8
4 Server: nginx
5 Vary: Accept-Encoding
6 X-Okta-Request-Id: c0f4459182f9646dfe487d0d534d32b
7 X-Xss-Protection: 0
8 P3p: CP="IDN"
9 Set-Cookie: sid=""; Version=1; Path=/; Max-Age=0
10 Content-Security-Policy-Report-Only: default-src 'self' kpmgstaging.oktapreview.com *.oktadn.com; connect-src 'self' kpmgstaging.oktapreview.com kpmgstaging-admin.oktapreview.com *.oktadn.com *.mixpanel.com *.mapbox.com *.mils.oktapreview.com kpmgstaging.kerberos.oktapreview.com kpmgstaging.mils.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oimanager.okta.com data: data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com; script-src 'unsafe-inline' 'unsafe-eval' 'self' kpmgstaging.oktapreview.com *.oktadn.com; style-src 'unsafe-inline' 'self' kpmgstaging.oktapreview.com *.oktadn.com; font-src 'self' kpmgstaging.oktapreview.com *.oktadn.com *.mixpanel.com *.mapbox.com *.mils.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 https://oimanager.okta.com data: data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com; blob: font-src 'self' kpmgstaging.oktapreview.com data: *.oktadn.com fonts.gstatic.com; frame-ancestors 'self'
11 Content-Security-Policy: default-src 'self' kpmgstaging.oktapreview.com *.oktadn.com; connect-src 'self' kpmgstaging.oktapreview.com kpmgstaging-admin.oktapreview.com *.oktadn.com *.mixpanel.com *.mapbox.com *.mils.oktapreview.com kpmgstaging.kerberos.oktapreview.com kpmgstaging.mils.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 https://oimanager.okta.com data: data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com; script-src 'unsafe-inline' 'unsafe-eval' 'self' kpmgstaging.oktapreview.com *.oktadn.com; style-src 'unsafe-inline' 'self' kpmgstaging.oktapreview.com *.oktadn.com; font-src 'self' kpmgstaging.oktapreview.com *.oktadn.com *.mixpanel.com *.mapbox.com *.mils.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 https://oimanager.okta.com data: data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com; blob: font-src 'self' kpmgstaging.oktapreview.com data: *.oktadn.com fonts.gstatic.com; frame-ancestors 'self'
12 X-Rate-Limit-Limit: 600
13 X-Rate-Limit-Remaining: 599
14 X-Rate-Limit-Reset: 1711017463
15 Accept-CH: Sec-CH-UA-Platform-Version
16 Cache-Control: no-cache, no-store
17 Pragma: no-cache
18 Expires: 0
19 Set-Cookie: autolaunch_triggered=""; Expires=Thu, 01-Jan-1970 00:00:10 GMT; Path=/
20 Set-Cookie: JSESSIONID=716AF561D1D19CDF3A790F8B0F8FA2A41; Path=/; Secure; HttpOnly
21 Set-Cookie: t=default; Path=/
22 X-Frame-Options: SAMEORIGIN
23 X-Content-Type-Options: nosniff
24 Content-Language: en
25 Strict-Transport-Security: max-age=315360000; includeSubDomains
26 X-Robots-Tag: noindex, nofollow
27
28 <!DOCTYPE html>
29
30 <html>
31 <link href="https://opstatic.oktadn.com/assets/css/sections/interstitial.c200c9e9e8c971dad6dd6597ab21f8.css" rel="stylesheet" type="text/css"/>
32 <div class="new-interstitial" id="new-interstitial">
33 <div id="interstitial-content-container" class="interstitial-dark-blue-brand">
34 
35 <div id="okta-auth-heading">
36 Signing in...
```

Instance 4: (Informational)

Screenshots:

Vulnerability	12. Concurrent User Session		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	It is the web application design decision to determine if multiple simultaneous logons from the same user are allowed from the same or from different client IP addresses. If the web application does not want to allow simultaneous session logons, it must take effective actions after each new authentication event, implicitly terminating the previously available session, or asking the user (through the old, new or both sessions) about the session that must remain active.			
URL	https://kpmgstaging.oktapreview.com/app/UserHome?session_hint=AUTHENTICATED			

Screenshots:

Remediation	It is recommended for web applications to add user capabilities that allow checking the details of active sessions at any time, monitor and alert the user about concurrent logons, provide user features to remotely terminate sessions manually, and track account activity history (logbook) by recording
-------------	--

	multiple client details such as IP address, User-Agent, login date and time, idle time, etc. There are two possible ways to have your applications handle a login attempt that exceeds the allowed number. The default is that previous sessions are invalidated and if the user tries to use his initial session he will be redirected to “your-page-here”. This is probably best for most applications. The other option is to throw an exception after the login attempt and keep the former session(s) valid. To do that, add the attribute error-if-maximum-exceeded="true" to the <concurrency-control/>.
(Closing/Down grading) Justification	

Vulnerability	13. CBC-mode Encryption in TLS (Lucky 13 attack)		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	A vulnerability exists in the TLS and DTLS protocols that may allow an attacker to recover plaintext from TLS/DTLS connections that use CBC-mode encryption. The attacks apply to all TLS and DTLS implementations that are compliant with TLS 1.1 or 1.2, or with DTLS 1.0 or 1.2. Tool Used: testssl.sh			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com <u>Instance 2:</u> https://kpmgstaging.kerberos.oktapreview.com			

Instance 1: (Informational)

Screenshots:

```

Start 2024-03-21 13:20:24 --> 75.2.32.98:443 (kpmgstaging.oktapreview.com) <<--
rDNS (75.2.32.98): a71653d1ac0df114f.amazonaws.com
Service detected: HTTP

Testing vulnerabilities
Heartbleed (CVE-2014-0160) not vulnerable (OK), no heartbeat extension
CCS (CVE-2014-0224) not vulnerable (OK)
Ticketbleed (CVE-2016-9244), experiment. not vulnerable (OK), reply empty
ROBOT not vulnerable (OK)
Secure Renegotiation (RFC 5746) supported (OK)
Secure Client-Initiated Renegotiation likely not vulnerable (OK), timed out
CRIME, TLS (CVE-2012-4929) not vulnerable (OK)
BREACH (CVE-2013-3587) no gzip/deflate/compress/br HTTP compression (OK) - only supplied "/" tested
POODLE, SSL (CVE-2014-3566) not vulnerable (OK)
TLS_FALLBACK_SCSV (RFC 7507) No fallback possible (OK), no protocol below TLS 1.2 offered
SWEET32 (CVE-2016-2183, CVE-2016-6329) not vulnerable (OK)
FREAK (CVE-2015-0204) not vulnerable (OK)
DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK)
make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=D685BFC938D0E119FBD806C45E758B7C0B53620F2B79BD5F7A569B943EDB0CC
LOGJAM (CVE-2015-4000), experimental not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with <= TLS 1.2
REAST (CVE-2011-3388) not vulnerable (OK), no SSL 3 or TLS 1
LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses cipher block chaining (CBC) ciphers with TLS. Check patches
Winshock (CVE-2014-6321), experimental not vulnerable (OK) - CAMELLIA or ECONE_RSA GCM ciphers found
RC4 (CVE-2013-2566, CVE-2015-2808) no RC4 ciphers detected (OK)

Done 2024-03-21 15:17:04 [9921s] --> 75.2.32.98:443 (kpmgstaging.oktapreview.com) <<--

```

Instance 2: (Informational)

Screenshots:

```

Start 2024-03-21 13:22:05 --> 99.83.191.34:443 (kpmgstaging.kerberos.oktapreview.com) <-->

rDNS (99.83.191.34): a71653d1ac0df114f.awsglobalaccelerator.com
Service detected: HTTP

Testing vulnerabilities

Heartbleed (CVE-2014-0160) not vulnerable (OK), no heartbeat extension
CCS (CVE-2014-0224) not vulnerable (OK)
Ticketbleed (CVE-2016-9244), experiment. not vulnerable (OK), reply empty
ROBOT not vulnerable (OK)
Secure Renegotiation (RFC 5746) supported (OK)
Secure Client-Initiated Renegotiation likely not vulnerable (OK), timed out
CRIME, TLS (CVE-2012-4929) not vulnerable (OK)
BREACH (CVE-2013-3587) no gzip/deflate/compress/br HTTP compression (OK) - only supplied "/" tested
POODLE, SSL (CVE-2014-3566) not vulnerable (OK)
TLS_FALLBACK_SCSV (RFC 7507) No fallback possible (OK), no protocol below TLS 1.2 offered
SWEET32 (CVE-2016-2183, CVE-2016-6329) not vulnerable (OK)
FREAK (CVE-2015-0204) not vulnerable (OK)
DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK)
make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=57D0882AD3D84B154A81B08A86EEC607864FD2E5D2CA9862407E20BD37CF670A
LOGJAM (CVE-2015-4000), experimental not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with <= TLS 1.2
BEAST (CVE-2011-3389) not vulnerable (OK), no SSL3 or TLS1
LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses cipher block chaining (CBC) ciphers with TLS. Check patches
Winshock (CVE-2014-6321), experimental not vulnerable (OK) - CAMELLIA or ECDHE_RSA_GCM ciphers found
RC4 (CVE-2013-2566, CVE-2015-2808) no RC4 ciphers detected (OK)

Done 2024-03-21 15:17:39 [9837s] --> 99.83.191.34:443 (kpmgstaging.kerberos.oktapreview.com) <-->

```

Remediation

To mitigate potential exploit for SSL/TLS virtual servers, you can configure the SSL profile to prefer non-CBC ciphers.

**(Closing/Down
grading)
Justification**

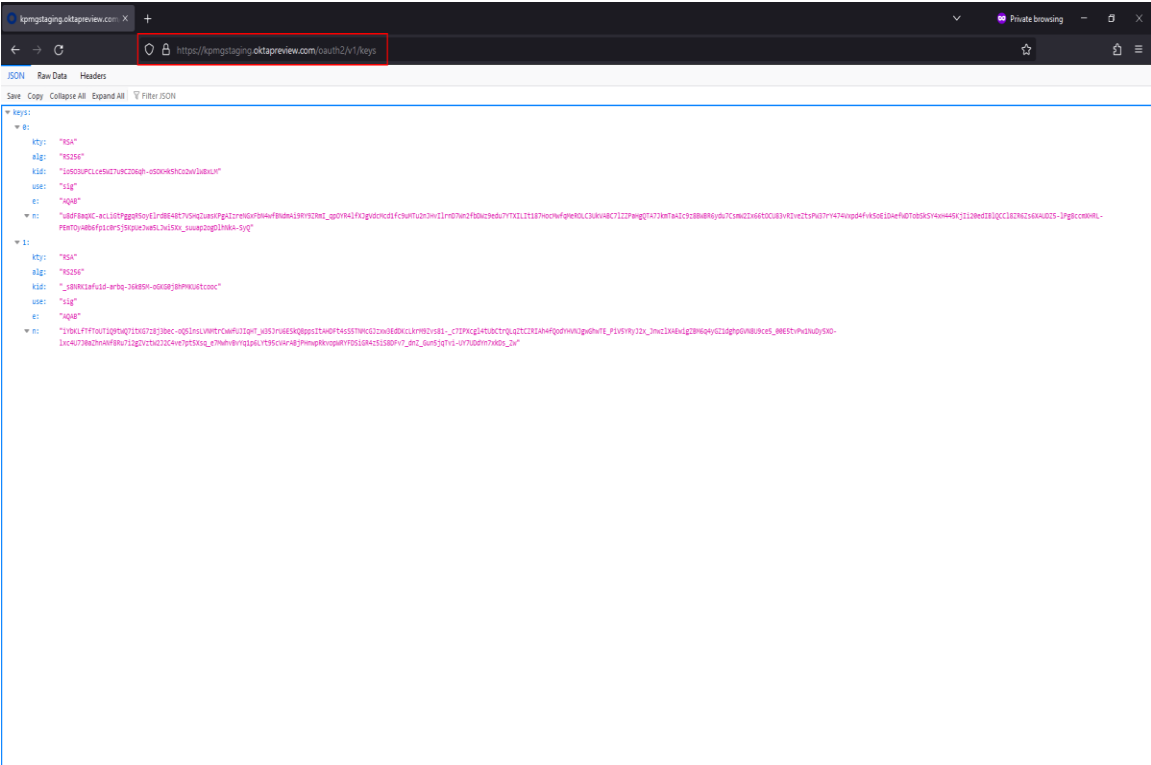
Vulnerability	14. Webserver Metafiles for Information Leakage		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	Server files discloses sensitive information or the structure of the server. For example: robots.txt, sitemap.xml, .DS_Store can lead to sensitive information leakage.			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com/oauth2/v1/keys <u>Instance 2:</u> https://kpmgstaging.kerberos.oktapreview.com/oauth2/v1/keys			

Instance 1: (Informational)

Reproduction Steps:

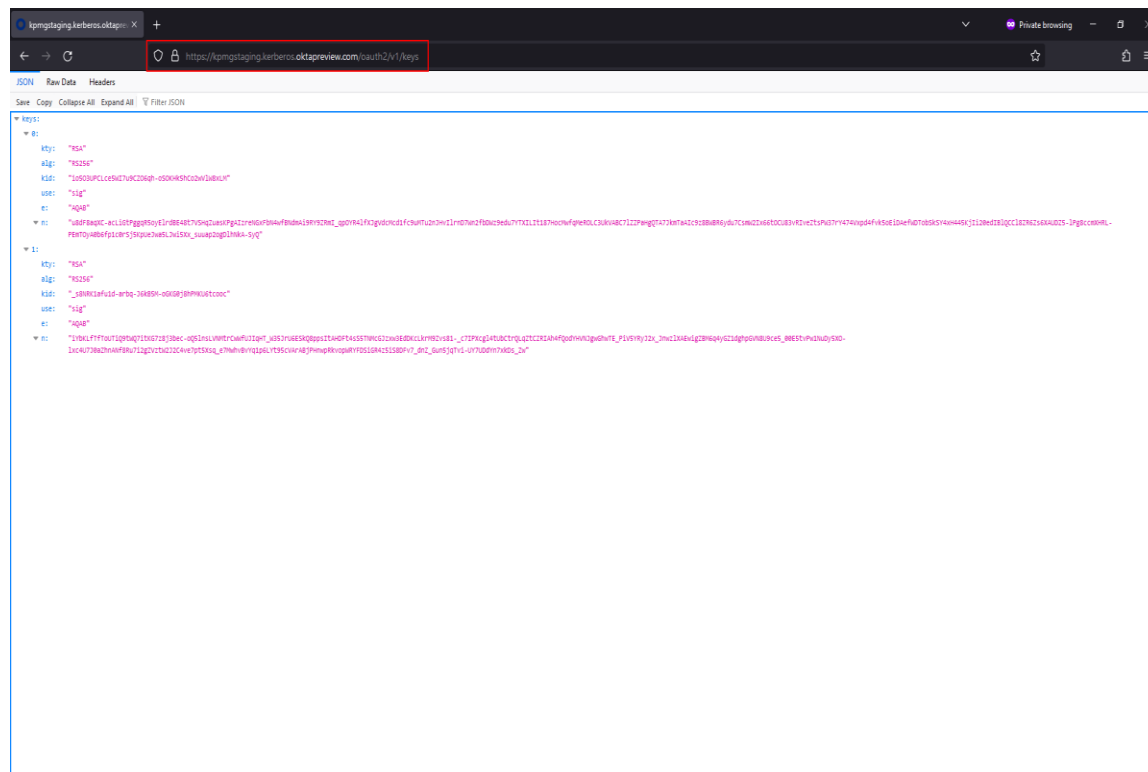
1. Open the target URL without any form of authentication

Screenshots:



Instance 2: (Informational)**Reproduction Steps:**

1. Open the target URL without any form of authentication

Screenshots:**Remediation**

All unwanted files should be removed. If some files are required then proper authorization control must be implemented so that those files are not available to everyone.

**(Closing/Down
grading)
Justification**

4. Appendix

4.1. Appendix A – Application Risk Score Matrix

The Application Risk Score is calculated by assigning a Risk Score value of 1, 2 or 3 to the following three categories and then summing the three values:

- Location and Access Vector
- Data Classification
- Business Criticality

1. Location and Access Vector – The location where the application would be hosted is one of the key factors in determining the threat landscape for that application. Internally hosted applications i.e. Applications that are hosted on KNET generally have a much more controlled threat landscape and hence lower risk of exposure to attackers and malicious entities. The risk therefore is significantly lower in comparison to applications hosted in the DMZ or on an Internet server at an Application Service Provider (ASP) or a third-party.

2. Data Classification - Data classification is a very critical aspect of the application and is a key in determining the risk posture of the application. Data classification mainly deals with the confidentiality and integrity of the data. The KPMG Information System Classification Standard classifies data into 4 different categories:

- DC 0 – Systems that handle information that is made generally available to Public
- DC 1 – Systems that handle information that is made generally available to KPMG personnel
- DC 2 – Systems that handle sensitive information that is restricted based on group or individual access and need to know.
- DC 3 – Systems that handle extremely sensitive information that is restricted based on group or individual access and need to know

The application risk score matrix classifies data as Public or Internal, Confidential and Restricted and maps these 3 classes to the DC ratings as follows:

- Public or Internal / DC0 and DC1
- Confidential / DC2
- Restricted / DC3

Note: DC0 and DC1 map the same risk score, i.e., 1.

Applications hosting public data are considered to be at a lower risk level than those hosting confidential or restricted data. The classification standard also imposes certain control requirements. Although these are mostly data protection controls, those relevant to secure software development process are incorporated into the software security policy and associated control standards.

Please refer to KPMG Information System Classification Standard for more details.

3. Business Criticality – Business criticality mainly deals with availability of the data and the application and is the third key factor in determining the risk posture of the application. There are 4 levels of classifications for Business Criticality:

- BC 0 / Low Impact–Firm could lose revenue or reputation if the application is down for several months.
- BC 1/ Important- Firm could lose substantial revenue, reputation or control if the application is down for several weeks.
- BC 2 / Critical- Firm could lose substantial revenue or reputation if the application is down for several days.
- BC 3 / Essential- Firm could not do business and/or generate revenue for any length of time without the application thus jeopardizing the survival of the firm.

Note: BC0 and BC1 map to the same risk score, i.e., 1.

ARS Matrix and Calculating the ARS

Location/Access Vector	Data Classification	Business Criticality
Hosted Internally(KNET,TPC) (Value = 1)	Public or Internal(DC0&DC1) (Value =1)	BC0 & BC1 (Value= 1)
Hosted in DMZ (Value= 2)	Confidential(DC2) (Value = 2)	BC2 (Value= 2)
Hosted Externally(Internet Third-party) (Value= 3)	Restricted(DC3) (Value=3)	BC3 (Value=3)

Use the following formula to determine ARS:

Value 1 = Value assigned to the applicable class of the Location / Access Vector attribute

Value 2 = Value assigned to the applicable class of the Data Classification attribute

Value 3 = Value assigned to the applicable class of the Business Criticality attribute

ARS = Value 1 + Value 2 + Value 3

Example:

ARS for an application that is hosted internally handles confidential data and has a business criticality rating of BC2 will be calculated as:

Value 1 = 1 (Hosted Internally)

Value 2 = 2 (Confidential Data)

Value 3 = 2 (Business Criticality BC2)

ARS = Value 1 + Value 2 + Value 3 = 1 + 2 + 2 = 5

4.2. Appendix B – 5 STAR Assessment Rating System

The 5-star assessment rating provides information on the likelihood and impact of defects present within an application. A perfect rating within this system would be 5 stars indicating that no high impact vulnerabilities were uncovered.

	One star rating is awarded to projects that have minimum of 1 or more Critical severity issues. Critical severity issues are High Likelihood, High Impact
	Two STAR rating is awarded to projects that have minimum of 1 or more High severity issues but no Critical severity issues. High severity issues are Low Likelihood, High Impact
	Three STAR rating is awarded to projects that have minimum of 1 or more Medium severity issues but no Critical or High severity issues. Medium severity issues are High Likelihood, Low Impact
	Four STAR rating is awarded to projects that have minimum of 1 or more Low severity issues but no Critical, High or Medium severity issues. Low severity issues are Low Likelihood, Low Impact
	Five STAR rating is awarded to projects that have no security issues

4.3. Appendix C – Terminology

Critical

Critical-priority issues have high impact and high likelihood. Critical-priority issues are easy to detect and exploit and result in large asset damage. These issues represent the highest security risk to the application. As such, they should be remediated prior to the go live date for applications or functionalities not yet in production. Applications with vulnerabilities already in production should fix critical priority issues within 5 days from the Preliminary Report date.

High

High-priority issues have high impact and low likelihood. High-priority issues are often difficult to detect and exploit, but can result in large asset damage. These issues represent a high security risk to the application. High-priority issues should be remediated prior to the go live date for applications or functionalities not yet in production. Applications with vulnerabilities already in production have 30 days from the Preliminary Report date to fix high priority issues.

Medium

Medium-priority issues have low impact and high likelihood. Medium-priority issues are easy to detect and exploit, but typically result in small asset damage. These issues represent a moderate security risk to the application. Medium-priority issues should be remediated prior to the go live date for applications or functionalities not yet in production. Applications with vulnerabilities already in production have 60 days from the Preliminary Report date to fix Medium priority issues.

Low

Low-priority issues have low impact and low likelihood. Low-priority issues can be difficult to detect and exploit and typically result in small asset damage. These issues represent a minor security risk to the application. Low-priority issues should be remediated in the next scheduled product update.

Informational

Informational findings are observations during application pen tests that may not possess exploitable security risks within an application at the time. These kind of findings may be related to best practices as per industry standards or unusual behavior from application. Informational findings do not have defined remediation SLA.

4.4. Appendix D – Methodology for Application Assessment

Application Foot printing – This phase identifies all applications running on particular client's infrastructure. Various tools are used to identify IP blocks, Hosts, Domains, Cross-domains and Child-domains using various tools. This helps in identifying all possible targets.

Application Discovery – In this phase all accessible applications running on client's infrastructure are identified.

Application Threat Modeling – In this phase each application is studied and all critical information is mapped. This helps to define objectives, dependencies, type of servers (web, application and database), roles, components, third-party blocks and use cases. It also helps to identify possible threat matrix and attack vectors.

Application Enumeration and Profiling – In this phase several tools are used to enumerate the target application. This helps in profiling the entire application, gathering information regarding modules, functionalities and resource attributes.

Security Control and Test Cases – A large repository of test cases and security controls required for applications is used as a guide for the application assessment. This is primarily based on OWASP and CWE industry standard and it helps to build up all test methodologies against known vulnerabilities.

Some of the security control categories we check for include the following:

- Information Gathering
- Configuration Management
- Authentication
- Authorization and Access Control
- Session Management
- Input Validation
- Encryption

Vulnerability Assessment – A complete vulnerability scanning is done using manual testing. This covers all the applicable security control test cases and ensures that all vulnerabilities on the application is detected.

Exploitation and Pen-testing – A full blown penetration and exploitation of discovered vulnerabilities is performed to detect the severity and possible impact of existing vulnerabilities.

Mitigation Strategies: Based on overall findings, a comprehensive plan for mitigation along with recommendation on secure coding best practices is provided. These strategies need to be implemented for overall security of application.

Reporting – All observations, findings, test cases and recommendations are documented in the final report. A risk rating is assigned to each discovered vulnerabilities based on CVSS v2 and CWE.

4.5. DSG Disclaimer Notice

Cybersecurity threats are continually changing, with new vulnerabilities discovered on a daily basis, and no application can ever be 100% secure no matter how much security testing is conducted. This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. DSG offers no warranties, representations or legal certifications concerning the applications or systems it tests.

All software includes defects: nothing in this document is intended to represent or warrant that security testing was complete and without error, nor does this document represent or warrant that the application tested is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. By using this reported information you agree that DSG shall be held harmless in any event.

Non-Production and Production Testing Advisory

It is important for the customer to understand that the engagement testing in non-production environments such as UAT (User Acceptance Testing) or QC (Quality Control) represents what is found only in such environments. If there are inaccuracies, omissions, or changes made during or after the testing engagement; this may impact findings visibility and ultimately the accuracy of this report. It is equally important to note that UAT and QC environments should ultimately mimic the production environment. DSG pen testers, unless at the request of the customer do not typically perform testing within a production environment for general stability and safety concerns. If production testing is a requirement by the SRM (Security Relationship Manager), please create a separate PTI (Penetration Testing Intake) form for as such and notify the DSG pen testers.

Modifications during Testing Engagements

If the customer performs any modifications or changes to the testing environment during an engagement, this may adversely impact the accuracy of the report and findings. Customers should be prepared to freeze changes where possible. If not possible, please notify the DSG pen testers of the intended change, time of change, and to which assets it will affect.